

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)

Department of Computer Science and Engineering

ASSESSMENT TOOL 1 – Secure Infrastructure Architecture

Course Code:	CSA5803	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO4 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 1
Weightage:	30% of CIA	Total Marks:	100
CO4 Statement:	Design Secure Infrastructure Architecture using DiagrammeR or Drawio.		
Student Name:	Adhithyan S	Reg. No.:	192421102
Section / Batch:	BTech IT / 3rd Year	Date:	

Instructions to Students

- Design a Secure Infrastructure Architecture for the selected application/system using DiagrammeR or Draw.io.
- Include essential components such as Firewall, WAF, Load Balancer, Web/Application Server, Database, IAM, IDS/IPS, and Monitoring/Logging wherever applicable.
- Clearly represent network zones, data flow, security controls, and trust boundaries in the architecture.
- Ensure the diagram is original, professionally formatted, clearly labelled, and submitted along with its editable source file.

Question Type	Focus Area	Questions	Marks
Secure Infrastructure Architecture	Conceptual Understanding	Q1	Q1 –100
GRAND TOTAL:			100 Marks

Code of Conduct

I Adhithyan S (192421102) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student: Adhithyan S

Q1 — Secure Infrastructure Architecture Design

Zoned, defense-in-depth architecture for a web application, with trust boundaries and data-flow annotations

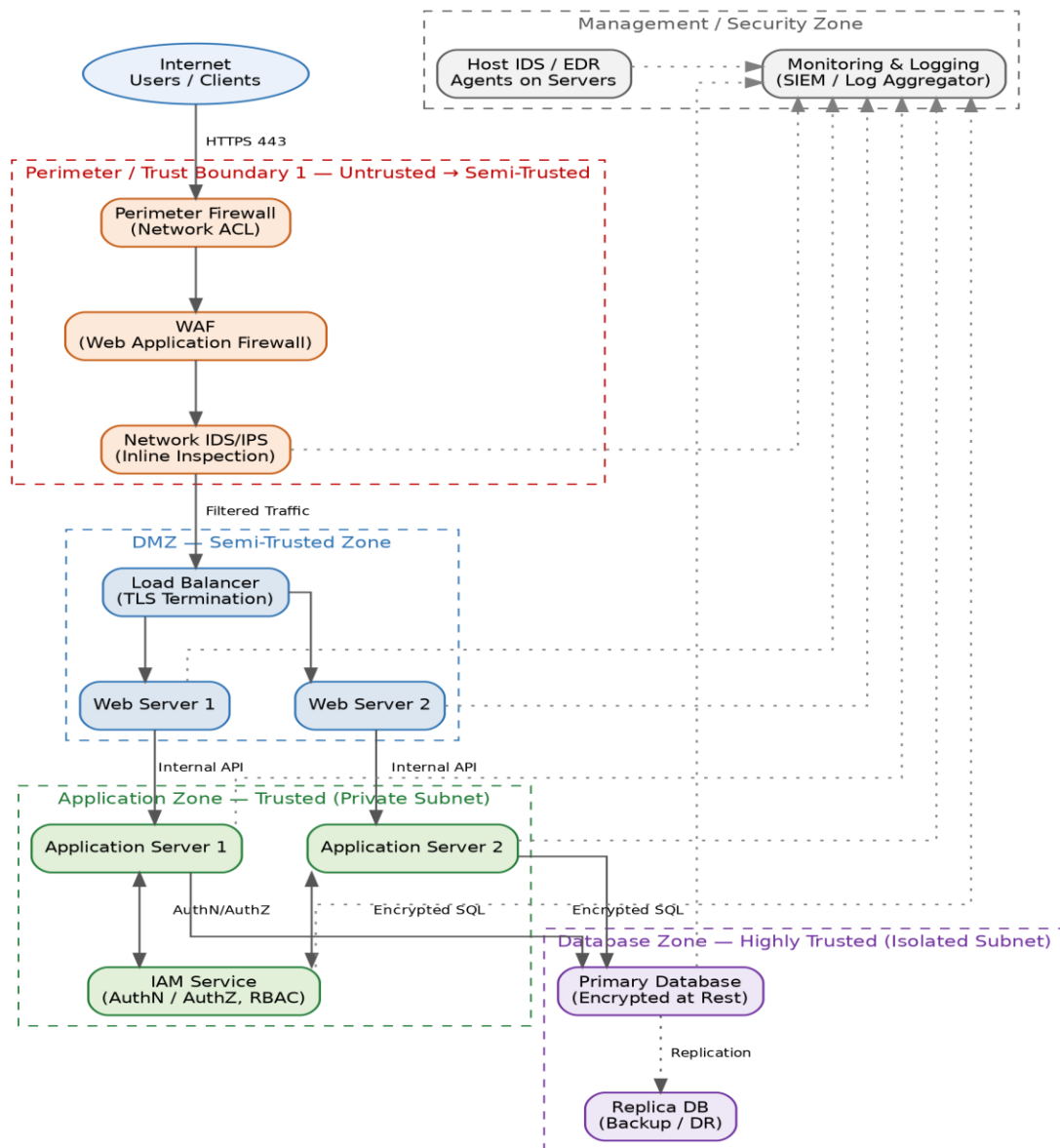
1. Objective & Problem Understanding

The goal is to design a secure infrastructure architecture for a typical three-tier web application (Web → Application → Database), applying defense-in-depth principles. The design must clearly show network zones, security controls at each boundary, data flow between components, and the trust boundaries that separate zones of differing sensitivity.

Selected system: A customer-facing e-commerce web application deployed on cloud infrastructure, consisting of a public web tier, an internal application tier, and an isolated database tier.

2. Architecture Diagram

The diagram below was produced using Graphviz/DiagrammeR-style DOT notation (functionally equivalent to Draw.io for this exercise) and shows all five zones, the required security components, and data-flow direction between them.



3. Components & Their Role

Component	Zone	Security Role
Perimeter Firewall	Perimeter	Filters inbound/outbound traffic by network ACL rules; first line of defense
WAF	Perimeter	Inspects HTTP(S) payloads; blocks SQLi, XSS, and OWASP Top-10 style attacks
Network IDS/IPS	Perimeter	Detects/blocks known attack signatures and anomalous traffic inline
Load Balancer	DMZ	Terminates TLS, distributes traffic across web servers, absorbs basic DDoS
Web Server(s)	DMZ	Serves the public-facing application; no direct database access

Component	Zone	Security Role
Application Server(s)	Application (Trusted)	Hosts business logic; only reachable from DMZ, not directly from Internet
IAM Service	Application (Trusted)	Centralized authentication/authorization (RBAC, MFA, token issuance)
Primary Database	Database (Highly Trusted)	Stores application data, encrypted at rest, reachable only from app tier
Replica DB	Database (Highly Trusted)	Provides backup/disaster-recovery copy via one-way replication
Host IDS/EDR Agents	Management	Endpoint-level detection running on each server
Monitoring & Logging (SIEM)	Management	Aggregates logs/alerts from every zone for correlation and audit

4. Network Zones & Trust Boundaries

Zone	Trust Level	Ingress Allowed From
Internet	Untrusted	N/A (external)
Perimeter	Untrusted → Semi-Trusted boundary	Internet, port 443 only
DMZ	Semi-Trusted	Perimeter zone only, via filtered/inspected traffic
Application Zone	Trusted	DMZ only, via internal API calls over private subnet
Database Zone	Highly Trusted / Isolated	Application zone only, via encrypted connections
Management Zone	Trusted (out-of-band)	Read-only log/telemetry feeds from all zones

Each arrow crossing a dashed cluster boundary in the diagram represents a trust-boundary crossing that is mediated by a security control — no zone can be reached directly by skipping the layer above it (e.g., the Internet cannot reach the Application or Database zones directly; only the DMZ is Internet-facing).

5. Data Flow Summary

- Client → Firewall → WAF → IDS/IPS → Load Balancer (TLS terminates here) → Web Server.
- Web Server → Application Server over an internal, private-subnet API call (no public routing).
- Application Server ↔ IAM Service for every authentication/authorization decision before processing a request.
- Application Server → Primary Database using an encrypted connection; database is not exposed to the DMZ or Internet.
- Primary Database → Replica Database via one-way replication for backup and disaster recovery.
- All tiers continuously stream logs/telemetry to the Monitoring & Logging (SIEM) service for centralized detection and audit.

6. Security Controls Applied (Defense-in-Depth)

Layer	Control
Network	Firewall ACLs restrict traffic to required ports/protocols only (443 inbound, internal ports between tiers)
Application	WAF blocks OWASP Top-10 style payloads before they reach the web server
Detection	Network IDS/IPS + Host IDS/EDR provide layered signature and behavioral detection
Identity	Centralized IAM enforces least privilege, RBAC, and MFA for all internal service calls
Data	Database encrypted at rest and in transit; isolated in its own subnet with no direct external route
Visibility	Centralized SIEM aggregates logs from every zone, enabling correlation and incident response
Resilience	Load balancing across redundant web/app servers; database replication for disaster recovery

7. Conclusion

The proposed architecture applies defense-in-depth by layering a firewall, WAF, and IDS/IPS at the perimeter; isolating the web tier in a DMZ; keeping application logic and identity services in a private trusted zone; and fully isolating the database in its own highly-trusted subnet reachable only from the application tier. Centralized IAM and a SIEM-based monitoring/logging layer span all zones, giving consistent authentication enforcement and end-to-end visibility. This zoned design ensures that a compromise of any single outer layer (e.g., the web server) does not directly expose the database or identity systems.

Note: This diagram and component list were produced with Graphviz/DOT as a DiagrammeR-equivalent tool. The editable source file (arch.dot) is included below for reference; when submitting, you may also recreate the same architecture visually in Draw.io and attach its .drawio source file as required by the assignment instructions.

8. Editable Source (DOT / DiagrammeR notation)

```

digraph SecureArchitecture {
  graph [fontname="Helvetica", rankdir=TB, splines=ortho, nodesep=0.55, ranksep=0.65,
  bgcolor="white", compound=true];
  node [fontname="Helvetica", fontsize=11, style="filled,rounded", shape=box, penwidth=1.3];
  edge [fontname="Helvetica", fontsize=9, color="#555555", penwidth=1.2];

  Internet [label="Internet\nUsers / Clients", shape=ellipse, fillcolor="#EAF1FB",
  color="#2E74B5"];

  subgraph cluster_perimeter {
    label="Perimeter / Trust Boundary 1 – Untrusted → Semi-Trusted";
    style="dashed"; color="#C00000"; fontcolor="#C00000"; fontsize=12; labelloc=t;
    FW [label="Perimeter Firewall\n(Network ACL)", fillcolor="#FDE9D9", color="#C55A11"];
    WAF [label="WAF\n(Web Application Firewall)", fillcolor="#FDE9D9", color="#C55A11"];
    IDPS_N [label="Network IDS/IPS\n(Inline Inspection)", fillcolor="#FDE9D9", color="#C55A11"];
  }
}

```

```

subgraph cluster_dmz {
    label="DMZ - Semi-Trusted Zone";
    style="dashed"; color="#2E74B5"; fontcolor="#2E74B5"; fontsize=12; labelloc=t;
    LB [label="Load Balancer\n(TLS Termination)", fillcolor="#DCE6F1", color="#2E74B5"];
    WEB1 [label="Web Server 1", fillcolor="#DCE6F1", color="#2E74B5"];
    WEB2 [label="Web Server 2", fillcolor="#DCE6F1", color="#2E74B5"];
}

subgraph cluster_app {
    label="Application Zone - Trusted (Private Subnet)";
    style="dashed"; color="#1E7B34"; fontcolor="#1E7B34"; fontsize=12; labelloc=t;
    APP1 [label="Application Server 1", fillcolor="#E2F0D9", color="#1E7B34"];
    APP2 [label="Application Server 2", fillcolor="#E2F0D9", color="#1E7B34"];
    IAM [label="IAM Service\n(AuthN / AuthZ, RBAC)", fillcolor="#E2F0D9", color="#1E7B34"];
}

subgraph cluster_db {
    label="Database Zone - Highly Trusted (Isolated Subnet)";
    style="dashed"; color="#7030A0"; fontcolor="#7030A0"; fontsize=12; labelloc=t;
    DB [label="Primary Database\n(Encrypted at Rest)", fillcolor="#EDE7F6", color="#7030A0"];
    DBR [label="Replica DB\n(Backup / DR)", fillcolor="#EDE7F6", color="#7030A0"];
}

subgraph cluster_mgmt {
    label="Management / Security Zone";
    style="dashed"; color="#595959"; fontcolor="#595959"; fontsize=12; labelloc=t;
    LOG [label="Monitoring & Logging\n(SIEM / Log Aggregator)", fillcolor="#F2F2F2",
color="#595959"];
    HIDS [label="Host IDS / EDR\nAgents on Servers", fillcolor="#F2F2F2", color="#595959"];
}

Internet -> FW [label=" HTTPS 443"];
FW -> WAF;
WAF -> IDPS_N;
IDPS_N -> LB [label=" Filtered Traffic"];
LB -> WEB1;
LB -> WEB2;
WEB1 -> APP1 [label=" Internal API"];
WEB2 -> APP2 [label=" Internal API"];
APP1 -> IAM [dir=both, label=" AuthN/AuthZ"];
APP2 -> IAM [dir=both];
APP1 -> DB [label=" Encrypted SQL"];
APP2 -> DB [label=" Encrypted SQL"];
DB -> DBR [label=" Replication", style=dotted];

WEB1 -> LOG [style=dotted, color="#7f7f7f", constraint=false];
WEB2 -> LOG [style=dotted, color="#7f7f7f", constraint=false];
APP1 -> LOG [style=dotted, color="#7f7f7f", constraint=false];
APP2 -> LOG [style=dotted, color="#7f7f7f", constraint=false];
DB -> LOG [style=dotted, color="#7f7f7f", constraint=false];
IDPS_N -> LOG [style=dotted, color="#7f7f7f", constraint=false];
HIDS -> LOG [style=dotted, color="#7f7f7f", constraint=false];
IAM -> LOG [style=dotted, color="#7f7f7f", constraint=false];
}

```